

INCIDENT RESPONSE PLAYBOOK

Security Operations Center: Threat Response Documentation

Phishing Attack | Malware Infection | Brute Force Attack

Prepared By	Omar Sherif & Radwa Khaled
Version	1.0 / Initial Release
Date	April 2026
Framework	NIST SP 800-61 Revision 2
Applies To	SOC Tier 1, Tier 2, IR Team, IT Administration

Executive Summary

This document presents a comprehensive Incident Response (IR) Playbook developed for Security Operations Center (SOC) analysts, covering three of the most prevalent and impactful cyber threat categories: **Phishing** Attacks, **Malware** Infections, and **Brute Force** Attacks. Each playbook follows the **NIST** SP 800-61 Revision 2 incident response lifecycle and is structured to serve as a practical, actionable reference for analysts at all tier levels.

The playbooks contained here in are designed to eliminate guesswork during high-pressure security incidents. Each one includes real-world **SIEM** detection queries (**Splunk/Wazuh**), explicit severity classification criteria, step-by-step containment and eradication procedures, realistic **Indicators of Compromise (IOC)** tables, tool references with usage context, and full **MITRE ATT&CK** technique mappings. Automation opportunities using **SOAR** platforms are also outlined as a forward-looking enhancement for each threat.

This playbook was produced in alignment with industry best practices from **NIST**, CISA, and the **MITRE ATT&CK** framework, drawing on real-world SOC workflows. It is intended as a living document to be reviewed and updated following every significant incident, continuously improving the organization's detection and response capabilities.

Introduction

What is an Incident Response Playbook?

An **Incident Response** Playbook is a structured, pre-defined set of procedures that guides a security team through the process of detecting, investigating, containing, and recovering from a specific type of cybersecurity incident. Unlike a general Incident Response Plan (IRP), which provides high-level guidance, a playbook is tactical and specific, telling the analyst exactly what to do, in what order, using which tools, and when to escalate.

Playbooks are essential in modern Security Operations Centers because they ensure consistency across analysts of different experience levels, reduce mean time to respond (MTTR), prevent critical steps from being missed under pressure, and create an auditable record of all actions taken during an incident.

The NIST SP 800-61 Framework

All playbooks in this document follow the **NIST Special Publication 800-61 Revision 2** incident response lifecycle, which consists of four core phases:

- **Preparation:** Establishing tools, policies, detection rules, communication chains, and analyst training before incidents occur.
- **Detection and Analysis:** Monitoring systems, identifying indicators of compromise, triaging alerts, and classifying severity.
- **Containment, Eradication, and Recovery:** Isolating affected systems, removing attacker footholds, and restoring normal operations.
- **Post-Incident Activity:** Documenting the incident timeline, conducting lessons-learned reviews, and updating detection capabilities.

Scope of this Playbook

This document covers the following three threat categories, selected based on their high frequency in real-world SOC environments:

- **Phishing Attack:** Email-based social engineering targeting credentials, malware delivery, or business email compromise.
- **Malware Infection:** Malicious software establishing persistence and communicating with attacker infrastructure.
- **Brute Force Attack:** Automated credential attacks targeting authentication services including RDP, VPN, SSH, and web applications.

Methodology

Research Framework

Each playbook was developed using the following research and design methodology:

- **Primary framework:** NIST SP 800-61 Revision 2 (Computer Security Incident Handling Guide)
- **Threat intelligence and technique mapping:** MITRE ATT&CK Framework (attack.mitre.org)
- **Detection logic:** Wazuh SIEM documentation, Splunk Security Essentials, Sysmon event ID reference
- **Tool references:** Official documentation for VirusTotal, ANY.RUN, CrowdStrike, Wireshark, AbuseIPDB

Playbook Structure

Each playbook in this document contains the following 16 standardized sections:

1. Objective	The goal of the response for this specific threat type
2. Scope	What systems, users, and vectors are covered and excluded
3. Trigger Conditions	Specific alerts or events that activate this playbook
4. Detection & Identification	SIEM queries, EventIDs, and tools for confirming the incident
5. Analysis (Investigation)	Step-by-step investigation questions and investigation methods
6. Severity Classification	Criteria for rating incident severity (Critical to Low)
7. Containment	Short-term and long-term isolation and blocking actions
8. Eradication	Complete removal of the threat and its persistence mechanisms
9. Recovery	Steps to safely restore affected systems and user accounts
10. IOC Table	Realistic indicators of compromise for the threat scenario
11. Tools Used	Tools referenced with their specific role in each playbook
12. MITRE ATT&CK Mapping	Technique IDs and tactics observed in this threat category
13. Communication & Escalation	Who to notify, when to escalate, and through what channel
14. Documentation & Reporting	Minimum information required in the incident ticket
15. Lessons Learned	Post-incident review questions and improvement actions
16. Automation (Bonus)	SOAR and automation opportunities for this threat type

PLAYBOOK 01

Phishing Attack

THREAT CATEGORY: SOCIAL ENGINEERING | NIST PHASE: INITIAL ACCESS

1. Objective

Detect, contain, and remediate phishing attacks targeting organizational users through email vectors to prevent credential theft, malware delivery, or business email compromise (BEC).

2. Scope

In Scope	All corporate email accounts, phishing links, malicious attachments, spoofed sender addresses, email-delivered malware
Out of Scope	SMS phishing (vishing/smishing) : addressed in a separate playbook
Applies To	SOC Tier 1 and Tier 2 Analysts, IT Help Desk, Email Administrators

3. Trigger Conditions

- User submits a Help Desk ticket reporting a suspicious email
- SIEM alert: known phishing domain detected in email delivery logs (**Wazuh / Splunk**)
- Email gateway flags a malicious attachment (Microsoft Defender / Proofpoint)
- URL in email matches an active threat intelligence **IOC** feed (**AlienVault OTX / VirusTotal**)
- Multiple users report emails from the same sender within a short time window

4. Detection & Identification

4.1 Email Header Analysis

Step 1: Pull raw email headers and check for spoofing indicators using MXToolbox (mxtoolbox.com/EmailHeaders.aspx):

- **SPF Result:** FAIL - sender IP not authorized by domain policy
- **DKIM Result:** FAIL - email signature does not match domain key
- **DMARC Result:** FAIL - domain does not validate the sender
- **From:** vs Reply-To: mismatch - strong indicator of impersonation

SIEM QUERY - SPLUNK: FIND ALL RECIPIENTS OF PHISHING EMAIL

```
index=email_logs | search sender="attacker@suspicious-domain.com"
| stats count by recipient
| sort -count
-- Output: Shows how many users received this email and who they are
```

SIEM QUERY - SPLUNK: FIND USERS WHO CLICKED THE PHISHING URL

```
index=proxy_logs dest_domain="malicious-login-page.com"
| table _time, src_ip, user, url
| sort _time
-- Output: Who clicked, from which IP, and exactly when
```

4.2 URL and Attachment Analysis

- Submit suspicious URL to URLScan.io. **DO NOT** click the link directly.

- **Get the file hash:** sha256sum suspicious.doc (Linux) or certutil -hashfile suspicious.doc SHA256 (Windows)
- Search hash on **VirusTotal**, check detection ratio across 70+ AV engines
- If hash unknown, submit to **ANY.RUN** sandbox for live behavioral analysis

5. Analysis (Investigation)

Answer the following four questions in sequence:

Did anyone click the URL?	Check proxy/firewall logs for outbound connections to the phishing domain
Were credentials submitted?	Check Azure AD / identity provider for logins after the email receipt timestamp
Did an attachment execute?	Check EDR process creation events on affected endpoints
Is this a known campaign?	Search IOCs on AlienVault OTX , identify known threat actor campaigns

6. Severity Classification

Severity	Trigger Condition	Response Time
Critical	Credentials confirmed stolen + active session hijacking in progress	< 15 minutes
High	Attachment executed on endpoint, C2 communication detected	< 1 hour
Medium	Link clicked, no confirmed credential entry detected	< 4 hours
Low	Email received by user, no interaction confirmed	< 24 hours

7. Containment

7.1 Short-Term Actions (Complete within 30 minutes)

- Block the phishing domain at the email gateway AND web proxy/firewall simultaneously
- **Quarantine all copies of the email from all mailboxes (M365: Security Center > Content Search > Search by sender > Purge Messages)**
- Disable the compromised user account immediately
- **Revoke all active sessions and refresh tokens (Azure AD: Revoke all refresh tokens)**
- **Isolate the endpoint if the malicious attachment was executed (EDR: Network Contain)**

7.2 Long-Term Actions (Complete within 24-48 hours)

- Force password reset for all affected users. Require **MFA** enrollment before access is restored.
- Submit phishing domain to PhishTank, Google Safe Browsing, and CISA Known Bad Domains
- Update email filtering rules to block similar sender patterns and domain variations
- Review all affected mailboxes for attacker-created inbox forwarding rules and remove them

8. Eradication

- Delete all instances of the phishing email from the mail server, then confirm with a second **SIEM** query
- Remove inbox rules created by the attacker (rules that forward, delete, or mark-as-read automatically)
- Scan affected endpoints for malware persistence using **EDR** full scan
- **Check for unauthorized OAuth app grants:** Azure AD > Enterprise Applications > All Applications

9. Recovery

- Restore user access using new credentials after **MFA** is confirmed active on the account
- Monitor the affected account closely for 7 days post-recovery for anomalous login activity
- Test that email filtering rules are functioning correctly using a controlled test email

10. Indicators of Compromise (IOC Table)

Scenario: Employee receives a fake Microsoft 365 security alert, clicks the link, and enters credentials on a phishing page.

IOC Type	Value	Description
Sender Email	support@micros0ft-help.com	Typosquatted domain: zero instead of letter O
Phishing URL	http://login-verify.net/office365	Fake Microsoft login page harvesting credentials
File Hash MD5	5d41402abc4b2a76b9719d911017c592	Malicious .docm attachment with macro payload
C2 IP Address	185.220.101.45	Phishing server IP (Tor exit node infrastructure)
Email Subject	ACTION REQUIRED: Your account will be suspended	Urgency-based social engineering lure
DMARC Result	fail	Sender domain fails DMARC authentication check
Domain Age	Registered 15 days before attack	Freshly registered domain: common phishing indicator

11. Tools Used

Tool	Purpose	Used In
Wazuh / Splunk SIEM	Search email and proxy logs; run detection queries; correlate events across users	All phases
VirusTotal	Analyze URLs, file hashes, and IPs against 70+ AV engines; identify malware family	Detection
URLScan.io	Safe visual inspection of phishing pages without visiting them directly	Detection
ANY.RUN	Interactive sandbox: execute suspicious files safely and observe behavior	Analysis

Tool	Purpose	Used In
MXToolbox	Parse raw email headers; verify SPF, DKIM, DMARC authentication results	Detection
Microsoft 365 Defender	Email quarantine, mailbox content search, session token revocation	Containment
AlienVault OTX	Threat intelligence enrichment: check if IOCs belong to known threat campaigns	Analysis

12. MITRE ATT&CK Mapping

Tactic	ID	Technique	Context
Initial Access	T1566	Phishing	Attacker sends malicious email to target user
Initial Access	T1566.001	Spearphishing Attachment	Email contains malicious file attachment
Initial Access	T1566.002	Spearphishing Link	Email contains link to credential-harvesting page
Credential Access	T1539	Steal Web Session Cookie	Attacker captures session cookie after victim logs in
Defense Evasion	T1656	Impersonation	Attacker impersonates trusted brand (Microsoft)
Collection	T1114.003	Email Forwarding Rule	Attacker creates inbox rule to exfiltrate email silently

13. Communication & Escalation

TIER 1 ANALYST Triage alert, confirms true positive, begins containment

TIER 2 ANALYST Escalate if: credentials stolen OR malware executed

IR MANAGER Escalate if: data breach suspected or multiple users impacted

LEGAL / COMPLIANCE Escalate if: PII exposure or regulatory breach is confirmed

14. Documentation & Reporting

- Exact timestamp of alert, detection, and each containment action
- List of all affected users and email addresses
- **Complete IOC list:** sender domain, URL, file hash, **C2** IP
- **SIEM** queries executed and their results (screenshot or CSV export)
- **All actions taken:** blocks applied, emails quarantined, accounts disabled
- **Final determination:** **True Positive** or **False Positive** with rationale

15. Lessons Learned

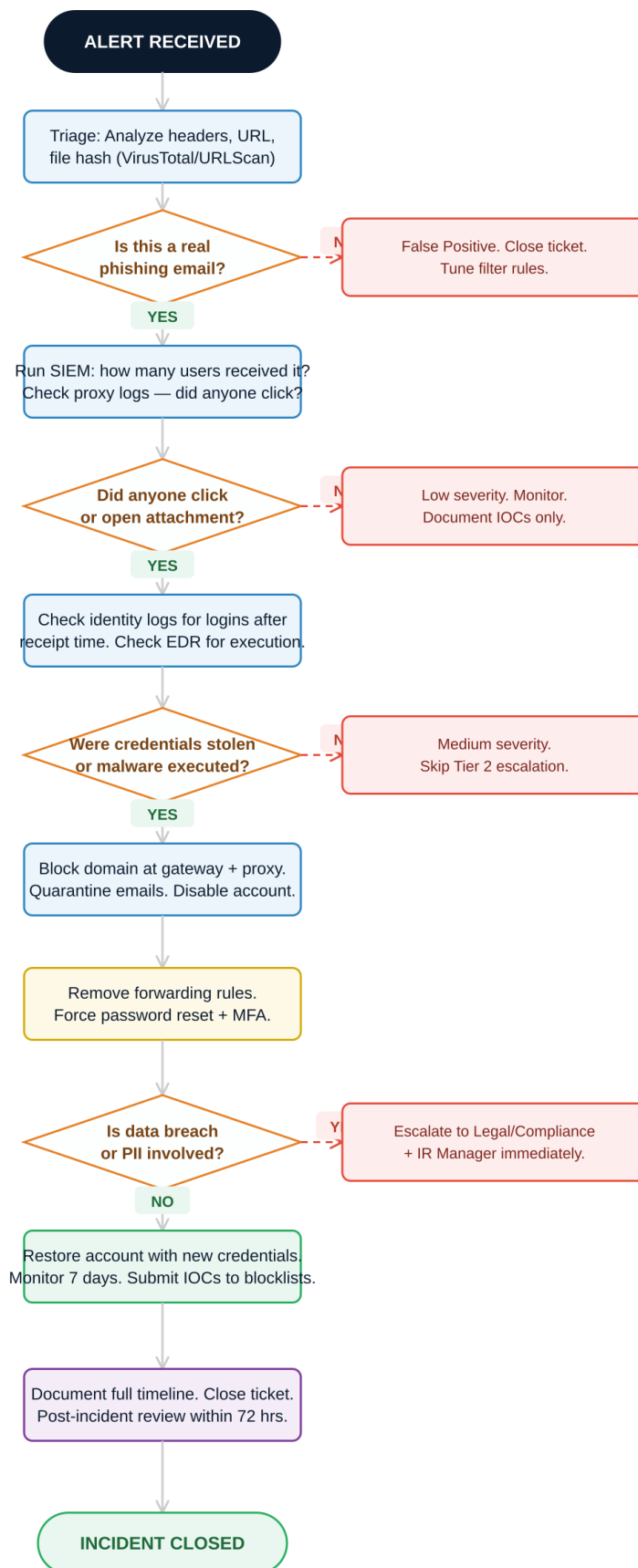
Conduct a post-incident review within 72 hours of incident closure:

1. How did the phishing email bypass our email gateway filters? Update rules if a gap is identified.
2. Could detection have been faster? Review **SIEM** alert thresholds and analyst response time.
3. Did affected users report the email themselves, or was it detected automatically? Evaluate user awareness training.
4. Was **MFA** active on all affected accounts? If not, enforce MFA immediately as a top remediation priority.
5. Did we have threat intel coverage for this domain before the attack? Evaluate threat intel feed subscriptions.

16. Automation Opportunities (Optional)

- > **SOAR Playbook:** When phishing alert fires, automatically quarantine matching emails across all mailboxes via M365 Graph API
- > **Auto-Enrich IOCs:** On every phishing **SIEM** alert, query **VirusTotal** API for URL/hash reputation and attach report to ticket
- > **Auto-Block:** Ingest PhishTank feed daily into firewall URL blocklist via scheduled **SOAR** job
- > **Auto-Notify:** When an account is locked due to phishing, automatically send security notification to the affected user

PLAYBOOK 01 — Phishing Attack Response Workflow



Legend

Action step

No-path action



Decision (Yes/No)

No branch

PLAYBOOK 02

Malware Infection

THREAT CATEGORY: ENDPOINT COMPROMISE | NIST PHASE: EXECUTION & PERSISTENCE

1. Objective

Detect, isolate, and fully remove malware from infected systems while preserving forensic evidence and preventing lateral movement or data exfiltration across the network.

2. Scope

In Scope	All endpoints (Windows/Linux/macOS), servers, all malware families (ransomware, RAT, trojan, worm, spyware)
Out of Scope	Mobile device malware: handled by the MDM/Mobile Security team
Applies To	SOC Tier 1 and Tier 2, Endpoint Security Team, System Administrators

3. Trigger Conditions

- **EDR alert:** malicious process execution detected (**CrowdStrike** Falcon / Microsoft Defender for Endpoint)
- **SIEM alert:** unusual outbound traffic to unknown IP on non-standard port
- Antivirus quarantine notification triggered on an endpoint
- User reports system running slowly, behaving strangely, or showing unusual messages
- **Ransomware** note discovered on desktop or file encryption activity detected by **EDR** behavioral engine

4. Detection & Identification

4.1 Confirm the Alert in EDR

Review the EDR console for: the triggering process, its parent process, files written, and network connections made.

SIEM QUERY - SPLUNK + SYSMON: FULL ACTIVITY TIMELINE OF INFECTED HOST

```
index=sysmon_logs host="INFECTED-PC-01"
| table _time, EventID, CommandLine, ParentImage, Image
| sort _time
-- Key Sysmon Event IDs:
-- EventID 1: Process Creation (what processes ran)
-- EventID 3: Network Connection (C2 communication)
-- EventID 11: File Creation (dropped payload files)
-- EventID 13: Registry Modification (persistence mechanism)
```

4.2 Identify the Malware Family

- **Step 1:** Get the file hash from **EDR** or manually: sha256sum malicious.exe
- **Step 2:** Search the hash on **VirusTotal**. Note: malware family name, detection ratio, associated IOCs
- **Step 3:** If hash has no **VirusTotal** hits, submit to **ANY.RUN** or Hybrid Analysis sandbox
- **Step 4:** In sandbox, observe: process tree, **C2** connections, dropped files, registry changes, mutex names

5. Analysis (Investigation)

A complete malware investigation must answer these 5 critical questions:

How did it get in?	Check email logs, proxy logs, USB device connection events, software install logs
What did it do?	Run Sysmon+Splunk timeline query for EventIDs 1, 3, 11, 13 on the infected host
Did it spread?	Query SIEM for EventID 4624 LogonType=3 originating from the infected host IP
Is C2 active?	Capture traffic with Wireshark , look for beaconing (regular interval connections)
Was data exfiltrated?	Review DLP logs and file access event logs for sensitive data movement

SIEM QUERY - LATERAL MOVEMENT CHECK (EVENTID 4624 LOGONTYPE=3)

```
index=windows_logs EventCode=4624 LogonType=3
| search src_ip="192.168.1.105"
| table _time, src_ip, dest_ip, user, LogonType
-- LogonType=3 is a network logon - classic lateral movement indicator
-- If results appear: attacker has moved beyond the initial endpoint
```

WIRESHARK FILTER: DETECT C2 BEACONING PATTERN

```
ip.addr == [infected_host_IP] && tcp.port == 443
-- Look for: regular intervals (every 30-60 seconds = beaconing pattern)
-- Look for: connections to DGA-generated domains (random-looking names)
-- Look for: encrypted traffic to unexpected geographic destinations
```

6. Severity Classification

Severity	Trigger Condition	Response Time
Critical	Ransomware spreading across network OR active data exfiltration confirmed	< 15 minutes
High	Confirmed C2 communication active OR Remote Access Trojan (RAT) installed	< 1 hour
Medium	Malware contained to single endpoint, no C2 communication confirmed	< 4 hours
Low	Potentially Unwanted Program (PUP), no confirmed malicious behavior	< 24 hours

7. Containment

7.1 Short-Term: Isolate First, Ask Questions Second

- **IMMEDIATELY** network-contain the infected host via **EDR** console. Do NOT wait for investigation to complete.
- CrowdStrike: Device > Network Contain | Manual: netsh interface set interface "Ethernet" admin=disabled
- Block identified **C2** IP and domain at the firewall immediately

- Take a VM snapshot if the infected host is virtual, preserving forensic state before any changes
- Disable the affected user account if credentials may have been stolen

7.2 Long-Term Actions

- Block malware hash in **EDR** policy to prevent execution on all endpoints organization-wide
- Identify all systems the infected host communicated with and check them for matching **IOCs**
- Consider application whitelisting on high-risk endpoints to prevent unknown executables

8. Eradication

Check all persistence locations systematically:

WINDOWS PERSISTENCE LOCATIONS TO AUDIT

```
-- Registry autorun keys (most common):
HKCU\Software\Microsoft\Windows\CurrentVersion\Run
HKLM\Software\Microsoft\Windows\CurrentVersion\Run

-- Scheduled tasks:
schtasks /query /fo LIST /v | findstr /i "task\|run\|status"

-- Services:
sc query type= all | findstr /i "service_name\|state"

-- Startup folder:
C:\Users\[user]\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup
```

- Use Autoruns (Sysinternals) to review ALL autostart locations, checking for unsigned or suspicious entries
- Use Process Hacker to inspect running processes and loaded DLLs for in-memory malware
- Run a full AV scan on the isolated machine after manual persistence removal
- Reimage the endpoint if full remediation confidence cannot be achieved

9. Recovery

- Restore from a clean backup that pre-dates the confirmed infection timestamp
- Reconnect to network ONLY after receiving a clean status confirmation from the **EDR** console
- Monitor the recovered machine closely for 14 days post-recovery
- Create a **SIEM** watchlist alert for all identified **IOCs** from this incident

10. Indicators of Compromise (IOC Table)

Scenario: Employee downloads a fake invoice.exe from a phishing email. Remcos RAT is installed. C2 established on TCP/4782.

IOC Type	Value	Description
File Name	invoice_2024.exe	Malicious executable disguised as a business invoice
SHA256 Hash	e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855	File fingerprint

IOC Type	Value	Description
		for EDR blocklisting
C2 Domain	update-service.ddns.net	Attacker C2 server using dynamic DNS
C2 IP Address	91.108.4.200	Resolved IP address of the C2 server
C2 Port	TCP/4782	Non-standard port to evade port-based detection
Registry Key	HKCU\Run\WindowsHelper	Persistence mechanism added by the RAT
Process Masq.	wmiprvse.exe (child of payload)	WMI process abuse for stealthy execution
Mutex Name	RemcosRAT_Mutex_v2	In-memory malware identifier

11. Tools Used

Tool	Purpose	Used In
CrowdStrike / Defender EDR	Process tree, network contain, file event timeline, malware removal	All phases
Sysmon + Wazuh/Splunk	Detailed Windows event telemetry for process, network, and registry	Detection & Analysis
VirusTotal	Hash, IP, and domain reputation across 70+ AV engines	Identification
ANY.RUN / Hybrid Analysis	Dynamic behavioral sandbox: observe malware execution safely	Analysis
Wireshark	Network packet capture: detect C2 beaconing and traffic patterns	Analysis
Autoruns (Sysinternals)	Enumerate all autostart locations and persistence mechanisms	Eradication

Tool	Purpose	Used In
Process Hacker	Inspect running processes, memory, and loaded DLLs	Eradication

12. MITRE ATT&CK Mapping

Tactic	ID	Technique	Context
Execution	T1204.002	User Execution: Malicious File	User double-clicks malicious invoice.exe
Persistence	T1547.001	Registry Run Keys	Malware adds itself to HKCU\Run for persistence
Defense Evasion	T1036	Masquerading	Malware disguises itself as a legitimate Windows process
Command & Control	T1071	Application Layer Protocol	C2 traffic tunneled through HTTP/HTTPS to blend in
Command & Control	T1571	Non-Standard Port	C2 uses TCP/4782 to evade port-based firewall rules
Lateral Movement	T1550.002	Pass the Hash	Attacker uses stolen NTLM hash to authenticate laterally
Exfiltration	T1041	Exfiltration Over C2 Channel	Stolen data sent through the same C2 connection

13. Communication & Escalation

TIER 1 ANALYST Confirm true positive, isolate infected endpoint, create incident ticket

TIER 2 ANALYST Escalate if: C2 confirmed active OR lateral movement detected

IR MANAGER Escalate if: ransomware spreading OR data exfiltration confirmed

LEGAL / DPO Escalate if: PII or regulated data may have been accessed or exfiltrated

14. Documentation & Reporting

- **Record the complete malware timeline:** first detection, isolation time, containment completion time
- **Document all IOCs:** file hashes, C2 IPs and domains, registry keys, mutex names, dropped file paths
- Record all **SIEM** queries executed and their results, attaching query output as evidence
- Note whether VM snapshot was taken and its storage location for forensic preservation

15. Lessons Learned

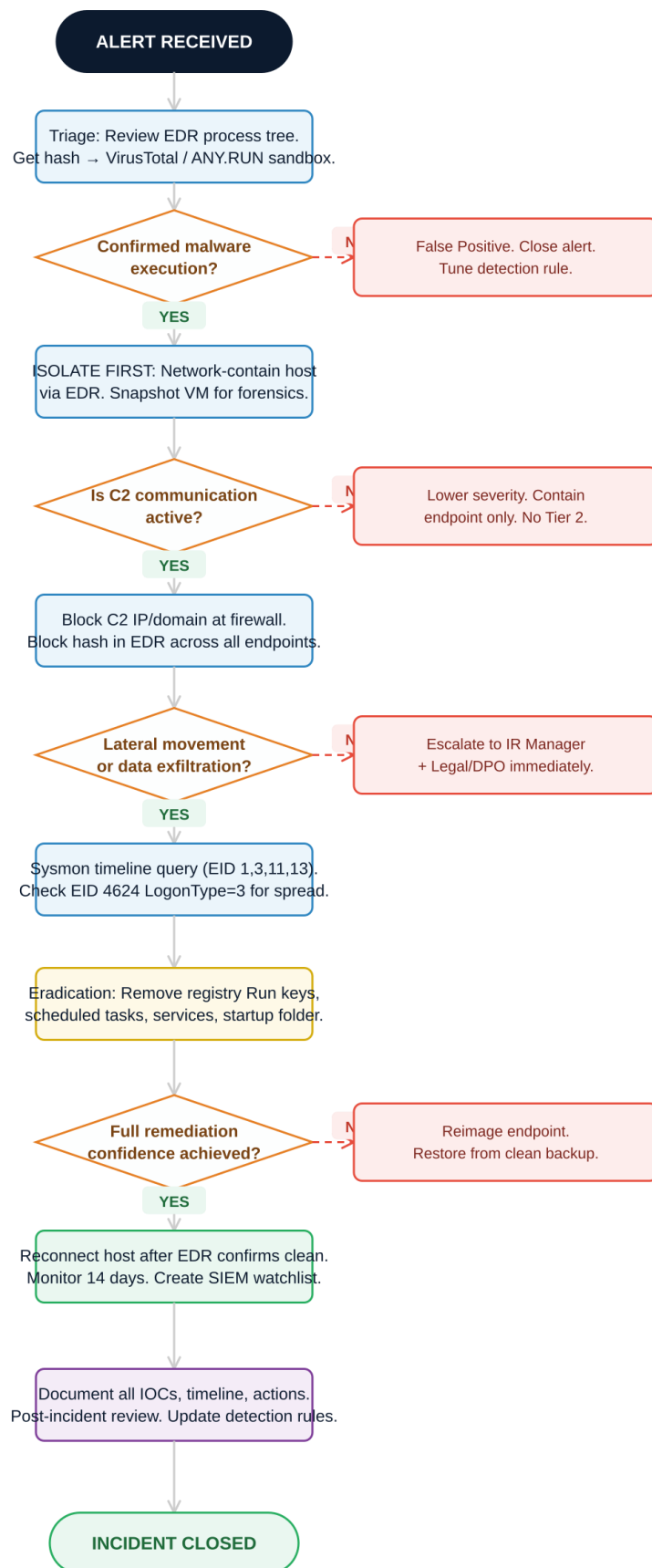
1. Was the endpoint missing **EDR** coverage, or did the malware evade detection? Evaluate coverage gaps.
2. Could the malware delivery have been blocked at the email gateway or web proxy?

3. Was the **C2** domain or IP in any threat intelligence feed we subscribe to before the incident?
4. Should we implement application whitelisting to prevent unknown executables from running?
5. How long between initial infection and detection? Calculate dwell time and set improvement targets.

16. Automation Opportunities (Optional)

- > **SOAR**: Auto-isolate host via **EDR** API the moment a ransomware behavioral alert fires (zero analyst wait time)
- > **Auto-Block C2**: Sync threat intel **IOC** feed to firewall block policy daily via API for proactive **C2** blocking
- > **Auto-Enrich**: On every **EDR** file alert, query **VirusTotal** API for hash reputation and attach to **SIEM** ticket
- > **SOAR Triage**: Auto-run **Sysmon** timeline query for infected host and attach results as first responder notes

PLAYBOOK 02 — Malware Infection Response Workflow



Legend

□ Action step

□ No-path action



Decision (Yes/No)



-- No branch

PLAYBOOK 03

Brute Force Attack

THREAT CATEGORY: CREDENTIAL ACCESS | NIST PHASE: INITIAL ACCESS

1. Objective

Detect, block, and investigate brute force credential attacks targeting authentication systems to prevent unauthorized access to user accounts and critical organizational services.

2. Scope

In Scope	VPN login portals, RDP (TCP/3389), SSH (TCP/22), web application login pages, Active Directory
Out of Scope	API key brute force: handled by the Application Security team
Applies To	SOC Tier 1 and Tier 2, Identity and Access Management (IAM), Network Security Team

3. Trigger Conditions

Login failure threshold	More than 10 failed logins (EventID 4625) from same IP within 5 minutes
Account lockout spike	More than 20 account lockouts (EventID 4740) across the domain in 10 minutes
Single account targeting	More than 5 failed logins against the same account within 3 minutes
Geographic anomaly	Login attempts from an unexpected country or region flagged by SIEM geo-detection
Off-hours pattern	High volume of attempts between 00:00 and 06:00 local time from a non-admin account

4. Detection & Identification

4.1 Key Windows Event IDs

EventID 4625	Failed login attempt: the primary indicator of brute force activity
EventID 4624	Successful login: critical to check to confirm if attack succeeded
EventID 4740	Account locked out: lockout spikes signal active brute force or spray
EventID 4776	Credential validation attempt at domain controller: NTLM authentication

SIEM QUERY - SPLUNK: DETECT TOP ATTACKING IPS BY FAILURE COUNT

```
index=windows_logs EventCode=4625
| stats count by src_ip, TargetUserName
| where count > 10
| sort -count
-- Output: Which IP is attacking which accounts, and how many times
```

SIEM QUERY - SPLUNK: DETECT CREDENTIAL STUFFING (1 IP, MANY ACCOUNTS)

```
index=windows_logs EventCode=4625
| stats dc(TargetUserName) as unique_users by src_ip
| where unique_users > 20
| sort -unique_users
-- Output: IPs trying many different usernames = credential stuffing pattern
```

SIEM QUERY - SPLUNK: CONFIRM IF ATTACK SUCCEEDED (4625 THEN 4624)

```
index=windows_logs (EventCode=4625 OR EventCode=4624)
| search src_ip="45.33.32.156"
| table _time, EventCode, TargetUserName, src_ip
| sort _time
-- Pattern: 4625, 4625, 4625... then 4624 = SUCCESSFUL BRUTE FORCE
-- If EventID 4624 appears: escalate IMMEDIATELY to Tier 2
```

5. Analysis: Attack Type Classification

Classic Brute Force	Same account, rapid-fire attempts. Fails quickly due to lockout. Easiest to detect.
Password Spray	Many accounts, 1-2 attempts per account per hour. Stays below lockout threshold. Harder to detect.
Credential Stuffing	Username/password pairs from known data breaches tested at scale. High success rate against password reusers.
Distributed Attack	Many IPs coordinate the attack. Each IP sends few attempts to evade per-IP threshold detection.

6. Severity Classification

Severity	Trigger Condition	Response Time
Critical	Successful brute force of an administrator or privileged account	< 15 minutes
High	Successful brute force of any account, active session confirmed	< 1 hour
Medium	Attack ongoing with high failure count, no successful login yet	< 4 hours
Low	Low-volume attempts, likely automated scanner, no pattern	< 24 hours

7. Containment

7.1 Short-Term: Block Immediately

- Block the attacking IP at the firewall immediately:

```
-- Linux firewall (iptables):
iptables -A INPUT -s 45.33.32.156 -j DROP

-- Windows Firewall (PowerShell):
New-NetFirewallRule -DisplayName "Block Attacker" -Direction Inbound -RemoteAddress 45.33.32.156 -Action Block
```

- Lock all targeted accounts if not auto-locked by the domain lockout policy

- **If a successful login was confirmed:** disable the account AND revoke all active sessions immediately
- Enable geo-blocking at the firewall or **VPN** gateway if attack originates from unexpected country

7.2 Long-Term Actions

- **Enforce account lockout policy:** lock account after 5 consecutive failed attempts
- Enforce **MFA** on all internet-exposed authentication services, as this blocks the majority of brute force success
- Implement rate limiting on web application login endpoints (max 5 attempts per minute per IP)
- Move **RDP** and **SSH** services behind a **VPN** to remove direct internet exposure
- Deploy a honeypot account (e.g., admin@domain.com) to detect future attacks with zero false positives

8. Eradication

- **Check EventID 4720 (New Account Created):** did the attacker create a backdoor account after gaining access?
- **Check EventID 4672 (Special Privileges Assigned):** did the attacker escalate privileges?
- Remove any unauthorized accounts discovered (**EventID 4720**) immediately
- **Check HaveIBeenPwned (haveibeenpwned.com) for affected email addresses:** were passwords in a known breach?
- Revoke all certificates and tokens that may have been exposed during the attacker access window

9. Recovery

- Restore locked legitimate accounts with new strong passwords (minimum 16 characters, randomly generated)
- Confirm **MFA** is active and enrolled before restoring access to any affected account
- Monitor affected accounts for 30 days for any residual unauthorized activity
- Test that the lockout policy is functioning correctly with a controlled test scenario

10. Indicators of Compromise (IOC Table)

Scenario: Attacker uses a credential stuffing tool with a leaked password list against the company VPN. Successful login at 03:47 UTC. Backdoor account created at 03:52 UTC.

IOC Type	Value	Description
Attacker IP	45.33.32.156	Primary attacking IP address (Linode VPS infrastructure)
ASN	AS63949 Linode LLC	Cloud VPS: common attacker infrastructure platform
Targeted Accounts	admin, john.doe, j.smith	Accounts targeted in the attack wave
Target Service	RDP TCP/3389	Exposed Remote Desktop service as the entry point
Attack Window	02:00 - 04:00 UTC daily	Off-hours attack pattern to avoid analyst detection
User-Agent	python-requests/2.28.0	Automated script indicator: not a human browser

IOC Type	Value	Description
Success Event	EventID 4624 at 03:47 UTC	Confirmed unauthorized access to account j.smith
Backdoor Event	EventID 4720 at 03:52 UTC	Attacker created backdoor account 5 minutes after access

11. Tools Used

Tool	Purpose	Used In
Wazuh / Splunk SIEM	EventID correlation for 4625, 4624, 4740: brute force detection and timeline	All phases
AbuseIPDB	Check attacking IP reputation: confidence score and historical abuse reports	Detection
Shodan	Investigate attacker IP infrastructure: what other services does it host?	Analysis
Fail2Ban	Linux auto-ban tool: blocks IPs after configurable failure threshold	Containment
Active Directory	Account lockout, session revocation, MFA enforcement, backdoor account audit	All phases
HavelBeenPwned	Check if affected user emails appear in known credential breach databases	Analysis
Wireshark	Analyze login traffic patterns and confirm scripted attack behavior	Detection

12. MITRE ATT&CK Mapping

Tactic	ID	Technique	Context
Credential Access	T1110	Brute Force	Rapid-fire password attempts against same account
Credential Access	T1110.003	Password Spraying	Slow attempts across many accounts to avoid lockout
Credential Access	T1110.004	Credential Stuffing	Leaked breach credentials tested at scale
Initial Access	T1078	Valid Accounts	Attacker authenticates using successfully stolen credentials
Persistence	T1136	Create Account	Attacker creates backdoor account after gaining access
Discovery	T1087	Account Discovery	Attacker enumerates user accounts after gaining access

13. Communication & Escalation

TIER 1 ANALYST Verify attack, block IP, check if any login succeeded

TIER 2 ANALYST Escalate if: successful login confirmed. Investigate post-access activity.

IR MANAGER + CISO Escalate if: privileged or administrator account was successfully compromised

14. Documentation & Reporting

- **Record the attack timeline:** timestamp of first **EventID 4625**, peak failure rate, and final outcome
- Log attacker IP, ASN, attack type classification, and all targeted accounts
- Document all containment actions with exact timestamps and analyst name
- Record whether attack succeeded, which account was compromised, and post-access activity observed

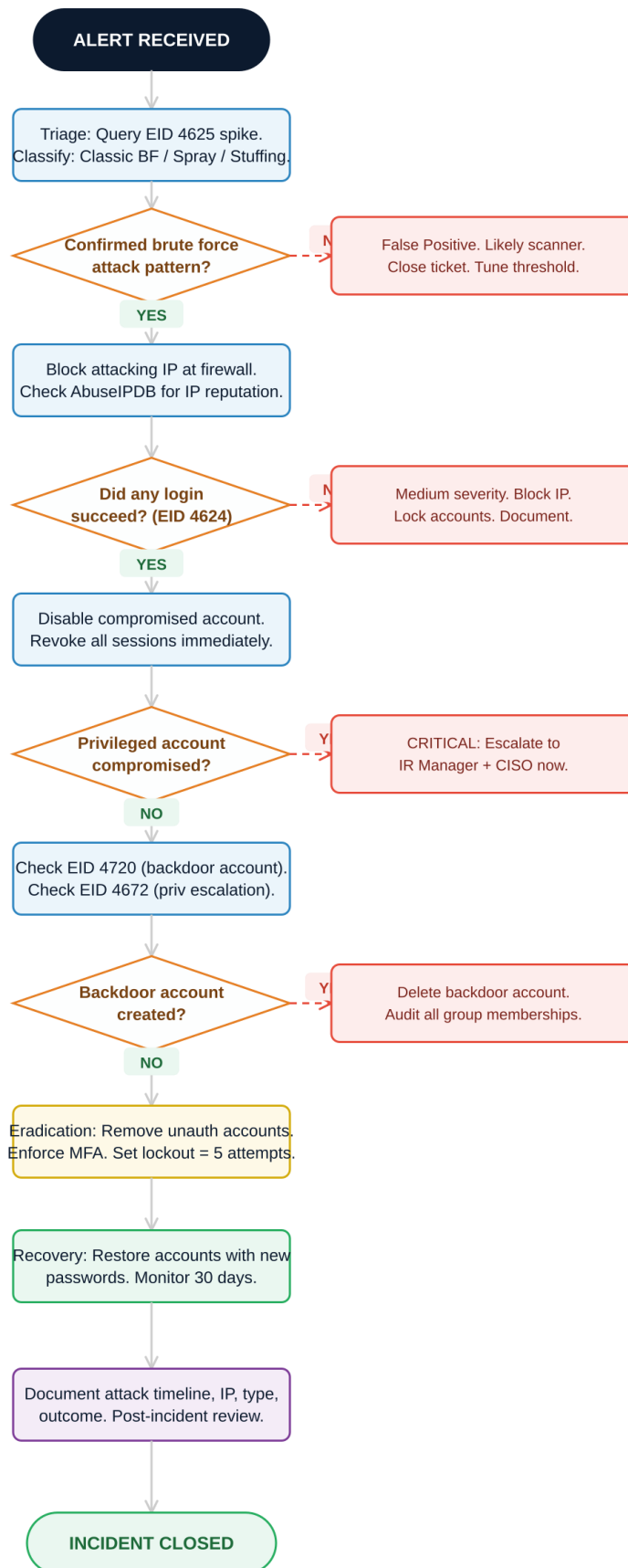
15. Lessons Learned

1. Was **MFA** deployed on the targeted authentication service? If not, enforce MFA immediately as top priority.
2. Was the lockout threshold too high, allowing too many failed attempts before locking?
3. Were the credentials used from a known breach? Check **HavelBeenPwned** and implement breach monitoring.
4. Should **RDP** and **SSH** be moved behind a **VPN** to remove direct internet exposure?
5. How quickly did the **SIEM** alert fire after the attack began? Evaluate threshold sensitivity.

16. Automation Opportunities (Optional)

- > **SOAR + Firewall API:** Auto-block IPs exceeding **EventID 4625** threshold (zero manual analyst intervention required)
- > **Auto-Reputation Check:** Every 4625 alert automatically queries **AbuseIPDB** API and appends confidence score to ticket
- > **Daily Report:** Scheduled **SIEM** saved search generates Top 10 Attacking IPs report emailed to SOC lead at 08:00
- > **Auto-Lockout:** When threshold exceeded for same account, automatically lock it and open a P1 incident ticket

PLAYBOOK 03 — Brute Force Attack Response Workflow



Legend

Action step

No-path action



Decision (Yes/No)

No branch

MITRE ATT&CK Consolidated Summary

The following table consolidates all **MITRE ATT&CK** techniques referenced across all three playbooks. Verify technique details at attack.mitre.org.

Threat	Tactic	Technique	ID	Context
Phishing	Initial Access	Phishing	T1566	Email-based attack
Phishing	Initial Access	Spearphishing Attachment	T1566.001	Malicious file
Phishing	Initial Access	Spearphishing Link	T1566.002	Malicious URL
Phishing	Credential Access	Steal Web Session Cookie	T1539	Session capture
Phishing	Defense Evasion	Impersonation	T1656	Brand spoofing
Phishing	Collection	Email Forwarding Rule	T1114.003	Inbox rule exfil
Malware	Execution	User Execution: Malicious File	T1204.002	User runs payload
Malware	Persistence	Registry Run Keys	T1547.001	Autorun entry
Malware	Defense Evasion	Masquerading	T1036	Process disguise
Malware	C2	Application Layer Protocol	T1071	HTTP/S C2
Malware	C2	Non-Standard Port	T1571	Port evasion
Malware	Exfiltration	Exfiltration Over C2 Channel	T1041	Data exfil via C2
Brute Force	Credential Access	Brute Force	T1110	Rapid attempts
Brute Force	Credential Access	Password Spraying	T1110.003	Low-and-slow attack
Brute Force	Credential Access	Credential Stuffing	T1110.004	Breach data reuse
Brute Force	Initial Access	Valid Accounts	T1078	Stolen credentials
Brute Force	Persistence	Create Account	T1136	Backdoor account
Brute Force	Discovery	Account Discovery	T1087	User enumeration